AI Security Control Map

A Practitioner Reference for GRC, Compliance, and Internal Audit

Regulated Financial Services | Enterprise AI Systems

55	7	4	6
Control objectives	Control domains	Columns per control	Regulatory frameworks

Atinuke Victoria Owete, CISM

How to use this document

What this is	A practitioner control reference for AI systems in regulated financial services. It specifies testable control objectives, the evidence an auditor must request, and the test steps they follow.
Control ID	Each control has a domain prefix and sequence number (e.g. DAT-04). IDs are referenced across the attestation template, regulatory mapping, and priority matrix.
Shall statement	The control objective is written as a 'shall' statement — a specific obligation. It is written in the language of what the organisation must have in place, not what the auditor observes.
Evidence Required	The artefacts the auditor must request to verify the control. Not what the control achieves — what must be produced as proof.
Test Steps	What the auditor does. Written in the imperative: Request, Verify, Confirm, Submit, Review. Numbered for sequencing.
Phase tags	Pre-req = must be in place before production deployment. Operational = ongoing monitoring or continuous control. Periodic = scheduled cadence (quarterly, annual).
Risk if absent	Critical = regulatory breach, customer harm, or incident with material financial/legal consequence. High = significant control gap. Medium = manageable if other controls compensate.
Priority matrix	Section 4 sequences all 55 controls by phase and risk for phased implementation programmes.
Attestation template	Section 5 provides a ready-to-complete control status form per AI system. One attestation per AI system in scope.
Regulatory mapping	Section 6 cross-references control IDs to EU AI Act, DORA, GDPR, ISO 42001, and NIST AI RMF obligations.
Relationship to ISO 27001	This map supplements your existing ISMS — it does not replace it. ISO 27001 controls apply to AI infrastructure. This map addresses AI-specific risk categories structurally absent from Annex A.
GitHub	The full portfolio — including the NIST AI RMF to ISO 27001 Bridge Document (Deliverable 2 of 2) — is at github.com/tinuowete/ai-governance-portfolio

Domain 1 | DAT — Data Governance & Training Data Security (8 controls)

Control ID	Control Objective (Shall Statement)	Evidence Required	Test Steps
DAT-01	Maintain a Training Data Registry documenting provenance, collection method, date, approved use scope, and accountable owner for every dataset used to train, fine-tune, or adapt any production AI system. Version-controlled; updated before each training run.	• Training Data Registry with all required fields per entry • Named approver sign-off on each dataset entry • Licence or contract on file for 3 sampled datasets	1. Request Training Data Registry 2. Cross-reference entries against training pipeline config 3. Verify required fields and approver sign-offs on sample entries 4. Confirm licence or contract on file for 3 sampled datasets
DAT-02	Verify and document the lawful basis under GDPR Art. 6(1) — and Art. 9 where applicable — for all personal data in AI training datasets prior to each training run.	• DPIA or lawful basis assessment per personal data dataset • Legal team sign-off referencing specific GDPR article • RoPA entry covering the training processing activity	1. List datasets flagged as containing personal data 2. Request DPIA or lawful basis assessment for each 3. Verify GDPR Art. 6(1) basis is explicitly cited 4. Confirm RoPA covers the training activity
DAT-03	Conduct and document a quality and bias assessment of each training dataset before use, identifying demographic representation gaps and discriminatory bias, with sign-off from a named quality and ethics reviewer.	• Training Data Quality and Bias Assessment report per dataset • Demographic distribution summary in assessment • Named quality reviewer AND ethics reviewer sign-offs • Risk acceptance record for any accepted deficiencies	1. Request quality/bias assessment reports 2. Verify assessment pre-dates training run 3. Confirm demographic representation is addressed 4. Verify both reviewer sign-offs are present and dated
DAT-04	Implement access controls, SHA-256 checksums, immutable audit logs, and pre-training integrity verification to protect training pipelines against data poisoning attacks.	• Storage ACL confirming write access restricted to named service accounts • SHA-256 checksum manifest dated at dataset approval • Pipeline logs showing pre-training integrity check passed • Immutable access logs for the relevant training run	1. Request access control config for training data storage 2. Verify write access restricted to named accounts 3. Confirm checksum manifest and pre-training verification log exist 4. Test by modifying staging copy — verify integrity check detects change
DAT-05	Apply data minimisation to AI model training. Document why personal data is necessary for the training objective and evaluate whether synthetic, anonymised, or pseudonymised alternatives are viable.	• Data minimisation assessment per personal data category • Documented evaluation of synthetic/anonymised alternatives • DPO or equivalent review confirmation	1. Request minimisation assessment for personal data datasets 2. Verify each personal data category is addressed individually 3. Confirm synthetic/anonymised alternatives were explicitly considered 4. Check DPO review signature

DAT-06	Ensure third-party training data contracts include provenance warranties, audit rights, notification obligations, and the right to require data removal if provenance cannot be verified.	• Executed contracts showing required clauses • Clause compliance checklist applied at onboarding • Risk acceptance with remediation plan for any missing clauses	1. Request contracts for all third-party training data providers 2. Apply clause checklist: provenance warranty, audit rights, notification, removal right 3. Identify missing clauses 4. Verify signed risk acceptance exists for any gaps
DAT-07	Define retention and disposal schedules for training datasets including secure deletion procedures and a documented process for GDPR Art. 17 deletion requests in the context of training data.	• Training Data Retention Schedule with periods and disposal methods • Disposal records for past-retention datasets • GDPR Art. 17 process document explicitly addressing training data	1. Request retention schedule 2. Verify periods are defined and legally justified per category 3. Sample 3 datasets — confirm retention not exceeded 4. Verify Art. 17 process specifically addresses training data
DAT-08	Maintain immutable audit logs of all training data access stored separately from the training pipeline, reviewed periodically for anomalous access patterns.	• 30-day access log export with required fields: identity, action, dataset, timestamp, source • Evidence of separate log storage from training pipeline • Most recent anomalous access review record	1. Request 30-day training data access log export 2. Verify all required fields present in each log entry 3. Confirm logs stored separately from training pipeline 4. Review most recent anomalous access review for completeness

> Training data deficiencies cannot be remediated through operational controls. A model trained on poisoned, biased, or unlawfully processed data carries that deficiency in its weights. Controls must apply before training commences.

> Most common gap: Absence of a Training Data Registry maintained as a controlled document accessible to compliance and audit, not just experiment tracking tools.

Domain 2 | MOD — Model Security & Supply Chain (8 controls)

Control ID	Control Objective (Shall Statement)	Evidence Required	Test Steps
MOD-01	Verify and document the provenance and authenticity of every AI model before deployment: developer identity, version, SHA-256 weight hash, source channel, and named approver for the specific use case.	• Model Provenance Record per model with all required fields • Model Card or technical documentation from developer • Verified hash comparison: computed vs. developer's published manifest	1. Request Model Provenance Record 2. Recompute weight hash and compare against registry 3. Confirm source is official developer repository (not a mirror) 4. Verify named approver reviewed Model Card for this specific use case
MOD-02	Require a Model Card meeting defined minimum content standards before production deployment, covering architecture, training data categories, evaluation results, known failure modes, bias evaluation findings, and deployment constraints.	• Model Card with all minimum content fields • Internal Model Deployment Assessment cross-referencing any gaps • Named technical reviewer sign-off pre-deployment	1. Request Model Card for deployed model 2. Apply content checklist against required fields 3. Identify gaps and verify internal Assessment addresses them 4. Confirm named reviewer sign-off before deployment
MOD-03	Conduct a third-party model vendor assurance assessment at onboarding covering security accreditations, data processing terms, model update practices, and incident notification procedures. Repeat annually and on material service changes.	• Completed AI Vendor Assurance Questionnaire • Current security accreditation (ISO 27001 or SOC 2 Type II, valid) • Documented assurance schedule and most recent reassessment evidence	1. Request questionnaire and certificates 2. Verify certificate is current 3. Confirm questionnaire covers all required topics 4. Verify last reassessment is within the defined cycle
MOD-04	Maintain an open-source model risk register documenting licence compliance assessment, verified provenance hash, current CVE search results, and assessment of the model developer community's security practices.	• Open-source model risk register with entries per model • Legally reviewed licence compliance assessment • CVE and researcher disclosure search results for each model version	1. Request open-source model risk register 2. Verify licence assessment is legally reviewed and current 3. Confirm model weights downloaded from official source with hash verified 4. Search current CVE databases for sampled model versions
MOD-05	Maintain model version control with complete history, change rationale, evaluation results, and tested rollback procedures. No model version goes to production without an approved change record. Third-party API deployments must pin model version explicitly.	• Model version history in model registry with change rationale and evaluations • Approved change record for most recent version transition • API config showing explicit version pin (not 'latest' alias) • Rollback runbook tested within 12 months	1. Request model version history 2. Verify each transition has an approved change record 3. For API deployments confirm model version is pinned, not aliased 4. Verify rollback runbook exists and was tested within 12 months
MOD-06	Verify the cryptographic integrity of model weights at: download, pre-deployment, and on a periodic production	• Integrity verification logs at all 3 checkpoints: download, pre-deployment, periodic	1. Request integrity verification logs for production model

	schedule. Log each verification result. Make integrity check a mandatory pipeline step that cannot be bypassed.	• Pipeline config confirming check is mandatory (cannot be bypassed) • Hash comparison against developer's published manifest for same version	2. Verify logs exist for all 3 checkpoints 3. Confirm hash matches developer published manifest 4. Verify integrity check is mandatory in CI/CD and cannot be skipped
MOD-07	Assess and document concentration risk from dependence on a single AI model provider, including substitutability assessment based on tested alternatives and a contingency plan with estimated migration timelines.	• AI Concentration Risk Assessment covering all material AI providers • Substitutability assessment based on tested (not theoretical) alternatives • CRO sign-off on the assessment and contingency plan	1. Request Concentration Risk Assessment 2. Verify all material AI providers are covered 3. Confirm substitutability assessment is based on tested proof-of-concept 4. Verify contingency plan includes tested migration timeline estimates
MOD-08	Maintain an AI Bill of Materials (AI-BOM) per production AI system listing all components with versions: foundation model, embedding model, orchestration frameworks, vector databases, and plugins. Update within 48 hours of any component change.	• AI-BOM per production system listing all required components with versions • Evidence BOM was updated within 48h of most recent component change • Process for monitoring AI-BOM components for known vulnerabilities	1. Request AI-BOM for system under review 2. Verify all required component categories are documented with versions 3. Compare BOM versions against production deployment config 4. Select most recent component change — verify BOM updated within 48 hours

> Model supply chain risk is the most underestimated control domain. A model API provider can change model behaviour without notification; an open-source model can be re-hosted with tampered weights. Provenance and version control are the first line of defence.

> Most common gap: Third-party API deployments using implicit version aliases (e.g. 'gpt-4' not 'gpt-4-0613'). Model behaviour changes with no change record and no audit trail.

Domain 3 | PRM — Prompt & Input Security (7 controls)

Control ID	Control Objective (Shall Statement)	Evidence Required	Test Steps
PRM-01	Treat system prompts as confidential configuration artefacts. Store in secrets management with restricted access, version-control all changes with approval records, and implement controls preventing model disclosure of system prompt contents to users.	• Secrets manager config showing restricted write access to system prompt • Version history with approval records for all prompt changes • Adversarial test results confirming model does not disclose system prompt	1. Request access control config for system prompt storage 2. Verify write access restricted to named principals 3. Check version history — confirm most recent change has approval record 4. Submit disclosure test prompts and verify model does not reveal system prompt
PRM-02	Implement technical controls to detect and block direct prompt injection attacks: input classifiers, context separation between user content and system instructions, and output monitoring for injection success indicators.	• Prompt injection detection mechanism spec and config • Pre-deployment adversarial test results: detection rate, false positive rate, technique coverage • Output monitoring config for injection success indicators	1. Request technical spec for injection detection mechanism 2. Review test set for coverage of known direct injection techniques 3. Verify detection rate meets acceptance threshold 4. Confirm output monitoring is configured and recent alerts have been reviewed
PRM-03	Implement controls to prevent indirect prompt injection through retrieved external content. Apply sandboxing, explicit content-vs-instruction separation in the system prompt, and monitoring for AI actions not explicitly requested by the user.	• RAG architecture documentation showing content isolation design • System prompt with explicit anti-instruction-following directives for retrieved content • Indirect injection test results: adversarial document submitted, model did not execute instructions	1. Review RAG architecture documentation 2. Verify system prompt contains explicit directives preventing retrieved content from being executed as instructions 3. Submit test document with adversarial instructions — verify model does not execute them 4. Review anomalous action monitoring config and recent alerts
PRM-04	Implement input validation and sanitisation: maximum length enforcement, rejection of known malicious patterns, PII detection at the input layer, and structured input validation for hybrid queries. Update jailbreak detection ruleset at least quarterly.	• Input validation config showing length limits and pattern rules • Test results confirming length enforcement and PII detection • Jailbreak detection ruleset updated within 90 days	1. Review input validation config 2. Test length enforcement — submit over-limit inputs and verify rejection 3. Submit PII test inputs — verify detection and routing per documented policy 4. Check jailbreak pattern ruleset update date — confirm within 90 days
PRM-05	Deploy a PII detection layer at all AI system input interfaces identifying personal data categories including name, national ID, financial account identifiers, health data, and biometric data. Log all detection events.	• PII detection config showing covered personal data categories and actions • 30-day detection event logs • Evidence of testing against representative financial services customer inputs	1. Request PII detection config for each AI interface 2. Submit test inputs for each required PII category — verify detection 3. Review 30-day detection event logs

			4. Verify action taken per category is consistent with documented policy
PRM-06	Implement jailbreak and adversarial prompt detection covering role-playing attacks, persona adoption, hypothetical framing, encoding obfuscation, and multi-turn context manipulation. Log and alert on detected attempts.	• Jailbreak detection mechanism spec • Red-team test results covering all specified attack categories • 30-day jailbreak attempt logs with evidence of alert review within SLA	1. Request jailbreak detection specification 2. Review red-team test results for coverage of all attack categories 3. Review 30-day jailbreak attempt logs 4. Sample 3 high-severity alerts — verify reviewed and actioned within defined SLA
PRM-07	Implement rate limiting: maximum requests per user per time unit, maximum per session before re-authentication, and automatic suspension for accounts exhibiting anomalous patterns consistent with scraping, probing, or denial-of-service.	• Rate limiting config for all user classes (end user, service account, admin) • 30-day enforcement event logs • Anomalous pattern detection config and alert history	1. Request rate limiting config — verify limits defined for all user classes 2. Test enforcement from a test account at rates exceeding defined limits 3. Review anomalous pattern detection config and alert history

Prompt and input security has the widest gap between developer awareness and GRC programme coverage. Most organisations focus on direct user input validation but leave the indirect injection attack surface — content retrieved from external sources — entirely uncontrolled.

Most common gap: Indirect prompt injection controls in RAG deployments. Retrieved documents, API responses, and customer-submitted files are treated as trusted content rather than as a potential adversarial instruction surface.

Domain 4 | OUT — Output Security & Reliability (7 controls)

Control ID	Control Objective (Shall Statement)	Evidence Required	Test Steps
OUT-01	Implement output guardrail mechanisms preventing outputs in prohibited categories: unauthorised regulated financial advice, customer data disclosure, discriminatory content, harmful instructions, and material factual errors. Document implementation approach and known limitations per guardrail.	• Guardrail technical specification per prohibited category • Pre-deployment and most recent quarterly adversarial test results • Known limitations documented with risk assessment • Output filtering activation rate logs (30 days)	1. Request guardrail spec — verify all prohibited categories covered 2. Review pre-deployment test results for each guardrail 3. Conduct live test against each prohibited category 4. Verify known limitations are documented and risk-assessed
OUT-02	Conduct adversarial guardrail testing at pre-deployment, quarterly thereafter, and after any change to the model, system prompt, or retrieval configuration. Use techniques that specifically target bypass, not only functional confirmation.	• Adversarial test suite per guardrail updated within 90 days • Test results showing bypass rates per technique • Pass/fail decision against defined thresholds with security reviewer sign-off	1. Request adversarial test suite per guardrail 2. Verify suite updated within 90 days with current bypass techniques 3. Review bypass rates — confirm within accepted thresholds 4. Confirm sign-off by AI security reviewer
OUT-03	Define an acceptable hallucination rate for each deployment context, measure continuously against a benchmark dataset, and establish escalation procedures triggered when the threshold is exceeded — including automated alerts and human review routing.	• Hallucination rate definition and measurement methodology • Benchmark dataset documentation • 90-day monitoring trend data • Alert threshold configuration and routing procedure	1. Request hallucination rate definition and methodology 2. Verify benchmark dataset is deployment-relevant 3. Review 90-day monitoring trend 4. Verify alert thresholds configured and routing procedure documented
OUT-04	For RAG systems: implement citation verification requiring a defined proportion of citations to be verified against source documents on a sampling basis. Monitor citation accuracy as a KRI with defined acceptable thresholds.	• Citation accuracy monitoring config and KRI definition • Most recent verification sample: sample size, methodology, accuracy rate, failed citation root causes • 90-day citation accuracy trend data	1. Request citation accuracy monitoring config 2. Review most recent verification sample — verify sample size is statistically adequate 3. Review 90-day trend data 4. For 3 failed citations, verify root cause was investigated and addressed
OUT-05	Implement a PII detection and redaction layer at the AI output interface identifying personal data relating to individuals other than the requesting user before any output reaches the user interface.	• Output-layer PII detection and redaction config showing covered categories • Test results confirming synthetic test individual PII is detected and redacted • 30-day output PII detection event logs	1. Request output-layer PII detection config 2. Submit prompts targeting synthetic test individual PII — verify redaction 3. Review 30-day output PII detection logs 4. Verify detected categories include financial identifiers relevant to deployment context
OUT-06	Define human review routing criteria for AI outputs: high-stakes output categories (credit decisions, complaint	• Human review routing policy with defined categories and criteria	1. Request human review routing policy — verify all required categories covered

	responses, regulatory disclosures), uncertainty flags, PII detection events, and potential prohibited content. Document reviewer qualifications and turnaround SLAs.	• Routing logic configuration in AI application layer • 30-day review logs showing category, reviewer, decision, and turnaround time • Head of Compliance sign-off on policy	2. Review 30-day routing logs — verify turnaround within SLA 3. Sample 3 review events — verify reviewer qualifications for category reviewed 4. Confirm Head of Compliance sign-off on policy
OUT-07	Maintain complete, tamper-evident output logs associating each output with: input, model version, session ID, user identity, retrieved context (for RAG), output filtering decisions, and timestamp. Retain consistent with DORA, EU AI Act, and conduct record-keeping requirements.	• Log completeness spec listing all required fields • 7-day sample export confirming all fields populated in practice • Log integrity controls (WORM or hash-chained storage) • Retention config consistent with DORA Art. 17 / EU AI Act Art. 12	1. Request log completeness specification 2. Sample 7-day log export — verify all required fields present 3. Verify log integrity controls prevent modification or deletion 4. Confirm retention period meets most stringent applicable regulation 5. Submit test query and verify resulting log entry is complete

Output security is where AI-specific risk intersects directly with financial services conduct regulation. Under Consumer Duty, the organisation is responsible for customer outcomes regardless of whether they are mediated by a human or an AI. Scale and speed make AI output failures qualitatively different from individual human errors.

Most common gap: Adversarial guardrail testing is almost universally absent. Functional testing confirms a guardrail activates on obvious examples. Adversarial testing confirms it cannot be bypassed — and these produce different results.

Domain 5 | ACC — Access Control & Identity (7 controls)

Control ID	Control Objective (Shall Statement)	Evidence Required	Test Steps
ACC-01	Implement MFA for all human access to AI system interfaces and administration panels. Implement certificate or token-based authentication for all service-to-service API calls. No exceptions for environments with access to production data.	• MFA config for all user-facing interfaces (no network bypass) • API authentication config showing token/certificate requirements per service account • No shared credentials across service accounts	1. Request authentication config for all AI interfaces 2. Verify MFA has no trusted-network bypass 3. Confirm all service accounts have unique non-shared credentials 4. Attempt access without valid credential — verify rejection
ACC-02	Implement role-based access controls defining at minimum: end user, content administrator, model administrator, and security reviewer. No role may combine end user access with administrative functions.	• RBAC config showing defined roles, permissions, and current user-to-role assignments • Evidence of least privilege applied (no excess permissions) • Access review completed within 12 months	1. Request RBAC config 2. Verify minimum 4 roles defined with no separation-of-duties violations 3. Sample 5 active accounts — verify role matches job function 4. Confirm most recent access review within 12 months
ACC-03	Implement secrets management for all AI API keys: centralised storage (not code repos or config files), maximum 90-day rotation, unique key per service and environment, immediate revocation on departure or suspected compromise, and usage audit logging.	• Secrets manager config confirming AI API keys stored centrally • Rotation log showing last rotation for each key within 90 days • Code repository secret scan report confirming no embedded API keys	1. Request secrets manager config for AI API keys 2. Verify each service has a unique key — no shared keys 3. Check rotation log — confirm all keys rotated within 90 days 4. Request code repo scan report — confirm no hardcoded API keys
ACC-04	Implement document-level access controls in the RAG retrieval layer so users can only retrieve documents they are authorised to access, verified against the IAM system at retrieval time, not only at login.	• RAG access control architecture documentation showing IAM integration at retrieval time • Test results: user cannot retrieve documents outside their permitted collection • Access control policy showing document classification to user-group mapping	1. Request RAG access control architecture documentation 2. Verify IAM is queried at retrieval time (not only at login) by reviewing application design 3. Create two test accounts with different access profiles — verify each retrieves only permitted documents 4. Submit low-privilege query for high-classification document — verify no result returned
ACC-05	Implement session isolation controls ensuring no information from one user session is accessible to any other session. Conduct cross-session data leakage	• Session isolation technical spec • Pre-deployment cross-session leakage test results • Caching config confirming session context is not persisted across users	1. Request session isolation spec 2. Conduct cross-session leakage test: establish session A with synthetic PII, terminate, establish session B, query for session A data

	testing before deployment and after any change to context management or caching.		3. Verify model does not return session A data in session B 4. Review caching config — confirm session context not cached across users
ACC-06	Apply PAM controls to all access to AI model infrastructure (hosting, training pipeline, vector database, model registry): just-in-time access approval, session recording, and quarterly recertification.	• PAM system config showing JIT approval and session recording for AI infrastructure roles • Current privileged access grant list with approval records • Session recordings for 3 recent sessions • Most recent quarterly recertification evidence	1. Request PAM config for AI infrastructure roles 2. Verify JIT is required — no standing privileged access without explicit approval 3. Review grant list — verify all within approved recertification period 4. Request 3 recent session recordings — verify completeness
ACC-07	Conduct quarterly access reviews for all AI system access: user accounts, service accounts, API keys, and administrator access. AI system owner sign-off required. Remediate anomalies within 10 business days.	• Access review records for preceding 4 quarters (date, accounts reviewed, anomalies, sign-off) • Remediation records showing completion within 10 business days • No lapsed review cycle	1. Request 4 quarters of access review records 2. Verify each quarterly review completed on schedule 3. For each anomaly, verify remediation within 10 business days 4. Confirm each review signed off by AI system owner

Access control for AI systems requires explicit extension of existing IAM and PAM frameworks. The most critical gap is the RAG retrieval layer: organisations apply rigorous document classification to their source repositories then deploy RAG systems that bypass those controls entirely at the vector database level.

Most common gap: Document-level access controls at the RAG retrieval layer. Source document access controls are not enforced at the vector database, making the AI system an effective bypass of the organisation's data classification scheme.

Domain 6 | MON — Monitoring, Logging & Incident Response (8 controls)

Control ID	Control Objective (Shall Statement)	Evidence Required	Test Steps
MON-01	Define and implement AI-specific KRIs per production system covering: hallucination rate, citation accuracy (RAG), appropriate and inappropriate refusal rates, retrieval precision/recall (RAG), input anomaly rate, output filtering activation rate, and user escalation rate. Each KRI must have a defined threshold and escalation procedure.	• KRI definition document with metric, methodology, source, threshold, alert level, and escalation per KRI • Monitoring config export confirming each KRI is implemented • 30-day KRI dashboard showing current values and any threshold breaches	1. Request KRI definition document 2. Verify all required KRIs defined with all required fields 3. Request monitoring config — verify each KRI is implemented with correct thresholds 4. Review 30-day dashboard for breaches — verify escalation occurred for any breach
MON-02	Define and implement a log completeness specification requiring each transaction to log: user identity, input text or hash, model version, retrieved context (RAG), output text or hash, output filtering decisions, and processing latency. Validate quarterly.	• Log completeness specification listing all required fields • Technical validation report confirming fields are in the log schema • Quarterly completeness sample: 100 log entries, all required fields present	1. Request log spec and schema documentation 2. Verify all required fields are in schema 3. Review most recent quarterly completeness sample 4. Submit test transaction and retrieve resulting log entry — verify all fields populated
MON-03	Define log retention periods consistent with DORA Art. 17 (minimum 5 years for critical/important functions), EU AI Act Art. 12, applicable conduct requirements, and GDPR data minimisation principles. Implement automated deletion at retention date.	• Log retention schedule with periods, legal basis, and regulatory requirement per log type • Automated deletion config at retention date • RoPA entry covering AI system log processing • Personal data minimisation approach documented (e.g. input hashing)	1. Request log retention schedule 2. Verify periods defined per log category and minimum meets most stringent applicable regulation 3. Confirm automated deletion is configured at defined retention date 4. Verify RoPA covers AI system log processing activities
MON-04	Define and maintain an AI Incident Classification Framework with 4 categories: Category 1 — security incidents, Category 2 — quality incidents, Category 3 — bias incidents, Category 4 — availability incidents. Each category must have defined severity levels, response timeframes, and escalation paths.	• AI Incident Classification Framework approved by CISO or Head of Technology Risk • AI incident category in the incident management system • Training records for response team on AI-specific classification • 3 examples of incidents classified under the framework	1. Request AI Incident Classification Framework 2. Verify all 4 categories defined with severity levels and response timeframes 3. Confirm framework integrated into incident management system 4. Review 3 recent AI incidents and assess whether classification is correct
MON-05	Implement a DORA notification assessment procedure defining criteria under which an AI incident constitutes a major ICT-related incident under DORA Art. 18. Document assessment outcomes for all incidents above the preliminary classification threshold.	• DORA notification assessment procedure referencing Art. 18 criteria explicitly • Assessment records for all AI incidents meeting preliminary threshold in past 12 months • Notification submissions where incidents were classified as notifiable	1. Request DORA notification assessment procedure 2. Verify procedure references Art. 18 criteria (not generic ICT criteria) 3. Review past 12 months of AI incidents — verify assessment records exist for threshold-meeting incidents

			4. For notifiable incidents, verify notifications submitted within DORA timeframe
MON-06	Define conditions under which an AI incident triggers EU AI Act Art. 73 reporting. Name a responsible individual for making the regulatory notification. Provide training on the notification obligation and timeframe.	• EU AI Act Art. 73 trigger assessment procedure for the organisation's AI system categories • Named responsible individual documented • Training records for responsible individual on Art. 73 obligations	1. Request Art. 73 trigger assessment procedure 2. Verify trigger categories are correct for organisation's AI system types 3. Confirm a named individual is documented as responsible 4. Review past 12 months — verify no Art. 73-threshold incident occurred without notification
MON-07	Conduct a post-incident review for every Category 1, 2, or 3 AI incident within 15 business days of closure. Cover AI-specific root cause categories, customer impact, regulatory notification assessment, and remediation actions with named owners.	• Post-incident review reports for Category 1–3 incidents (past 12 months), completed within 15 business days • AI-specific root cause categories addressed in each review • Remediation action tracking with due dates and completion status	1. Request post-incident review reports for Category 1–3 incidents 2. Verify completion within 15 business days of closure 3. Confirm AI-specific root cause categories were addressed 4. Check remediation tracking for outstanding items past their due date
MON-08	Implement anomalous usage pattern detection defining baselines per user class and generating alerts for deviations consistent with automated scraping, adversarial probing, social engineering, or insider threat activity.	• Anomalous usage detection config with baseline model and alert conditions per user class • 30-day alert logs with evidence of investigation within defined SLA • Alert response procedure documentation	1. Request anomalous usage detection config 2. Verify baseline models are defined per user class 3. Review 30-day alert logs 4. Sample 3 alerts — verify investigation within defined SLA 5. Confirm baseline model is updated on schedule to account for legitimate usage changes

> AI-specific KRI definitions are the most common gap in this domain. Organisations with mature security monitoring for infrastructure — availability, performance, security events — frequently have no KRIs for AI quality metrics such as hallucination rate, citation accuracy, or refusal rate. Quality degradation goes undetected until a customer complaint surfaces it.

> Most common gap: Absence of AI-specific KRIs with defined acceptable thresholds. Quality degradation in an AI system is not detectable through infrastructure monitoring and requires explicit definition of AI-specific metrics, baselines, and escalation thresholds.

Domain 7 | VND — Vendor & Third-Party AI Risk (8 controls)

Control ID	Control Objective (Shall Statement)	Evidence Required	Test Steps
VND-01	Conduct a structured AI vendor due diligence assessment before approving any AI vendor for use with production data or customer-facing applications, covering security accreditations, data processing practices, model update practices, incident notification, regulatory compliance, and concentration risk contribution.	• Completed AI Vendor Due Diligence Questionnaire with evidenced responses • Due diligence assessment report with risk ratings • Head of Technology Risk sign-off before vendor approval	1. Request DDQ and supporting documentation 2. Verify questionnaire covers all required topics 3. Confirm supporting evidence on file (current ISO 27001 cert, SOC 2 within 12 months) 4. Verify risk assessment completed and residual risks accepted at appropriate authority level
VND-02	Ensure AI model provider contracts include: audit rights, prohibition on training on organisational data, minimum 30-day advance model update notification, AI-specific failure SLAs covering elevated hallucination rates and guardrail failures, and liability allocation for AI failures causing customer harm.	• AI contracts with required clauses identified • Clause compliance checklist applied at contract signature • Risk acceptance with remediation plan for any missing clauses	1. Request contracts for AI vendors and model providers 2. Apply AI contract clause checklist 3. Identify missing required clauses 4. Verify risk acceptance signed for missing clauses with remediation plan
VND-03	Conduct ongoing AI vendor monitoring covering security bulletins, certification currency, operational incidents, and material service term changes. Escalate to third-party risk committee on material risk profile changes.	• Ongoing monitoring procedure with defined frequency, topics, and escalation criteria • Monitoring activity records for all active AI vendors (past 12 months) • Escalation records for vendors where risk changed • Current vendor risk register	1. Request ongoing monitoring procedure 2. Review monitoring activity records for all active AI vendors past 12 months 3. Verify monitoring covers all required topics 4. For a vendor with disclosed incident or terms change in past 12 months, verify monitoring identified change and triggered escalation
VND-04	Conduct an annual AI vendor concentration risk assessment identifying proportion of critical/important functions dependent on single providers, substitutability (tested, not theoretical), and operational impact of unavailability. Maintain a mitigation plan where concentration exceeds defined thresholds.	• AI Vendor Concentration Risk Assessment with concentration metrics per vendor • Mitigation plan for vendors above concentration threshold • CRO or Head of Operational Risk sign-off	1. Request Concentration Risk Assessment 2. Verify all critical/important function AI dependencies are covered 3. Assess concentration metrics for accuracy 4. For vendors above threshold, verify mitigation plan documented and in progress 5. Confirm appropriate authority sign-off
VND-05	Ensure a GDPR-compliant Data Processing Agreement is in place with every AI model provider processing personal data, including personal data in user queries, retrieved RAG documents, and fine-tuning datasets. Verify DPA includes processing purpose limitation, sub-processor list, and international transfer mechanism.	• DPAs executed with all AI providers processing personal data • DPA elements verified: purpose limitation, sub-processor list, transfer mechanism • RoPA entries covering AI processing activities	1. Identify all AI model providers receiving personal data 2. Request DPAs for each identified provider 3. Verify each DPA includes all required elements 4. For non-EEA providers verify international transfer mechanism (SCCs with TIA) 5. Confirm RoPA covers each processing activity

VND-06	Document and maintain a vendor exit strategy per material AI vendor covering technical migration steps, data portability requirements, estimated migration timeline and cost, business impact during migration, and exit trigger conditions. Test exit procedures annually for critical-function vendors.	• Exit strategy documentation per material vendor with all required elements • Exit procedure test evidence within past 12 months for critical-function vendors • Portability confirmation: data and config exportable in usable format	1. Request exit strategy for vendor under review 2. Verify all required elements documented 3. Request exit procedure test evidence within past 12 months 4. Verify migration timeline based on tested assumptions, not theoretical 5. Confirm data and config can be exported in usable format
VND-07	Register all AI service providers supporting critical or important functions in the DORA Register of Information. Subject them to DORA Art. 28 third-party risk management requirements. Assess each provider against DORA Art. 31 critical ICTSP criteria.	• DORA Register of Information entries for AI providers supporting critical/important functions • DORA-compliant third-party risk assessment per AI provider in register • Art. 31 critical ICTSP assessment per AI provider	1. Request DORA Register of Information 2. Identify all AI providers in register — verify classified as ICT third-party service providers 3. Verify DORA-compliant risk assessment exists for each 4. Review Art. 31 critical ICTSP assessment for each AI provider
VND-08	Require contractual notification from AI model providers within 72 hours of: material model behaviour changes, security incidents, data processing practice changes, sub-processor changes, or regulatory action affecting service capability. Define the organisation's response procedure per trigger type.	• Contractual notification clauses for all required trigger categories with binding timeframes • Notification log for past 12 months • Response procedure documentation per trigger type	1. Review AI vendor contracts for notification clauses covering all required triggers 2. Verify timeframes are contractually binding (not advisory) 3. Review notification log for past 12 months 4. For each notification received, verify organisation response completed within procedure timeframe

DORA Art. 28 applies fully to AI model providers supporting critical or important functions. This is a binding obligation from January 2025 and a documented area of supervisory focus. The most common gap is not risk awareness — it is the absence of AI-specific contractual clauses in commercial agreements that were signed before these risks were understood.

Most common gap: AI-specific contractual clauses — particularly model update notification and prohibition on using customer data for model training — are absent from most existing agreements. Standard SaaS and cloud contracts do not address these obligations.

Control Prioritisation Matrix

Implement in phase order, then by risk within each phase. All Pre-req Critical controls must be in place before production deployment.

Control ID	Domain	Implementation Phase	Risk if Absent	Implementation Complexity
DAT-01	DAT — Data Governance & Training Data Security	Pre-req	Critical	High
DAT-02	DAT — Data Governance & Training Data Security	Pre-req	Critical	High
DAT-04	DAT — Data Governance & Training Data Security	Pre-req	Critical	High
MOD-01	MOD — Model Security & Supply Chain	Pre-req	Critical	High
PRM-01	PRM — Prompt & Input Security	Pre-req	Critical	High
PRM-02	PRM — Prompt & Input Security	Pre-req	Critical	High
PRM-03	PRM — Prompt & Input Security	Pre-req	Critical	High
OUT-01	OUT — Output Security & Reliability	Pre-req	Critical	High
OUT-02	OUT — Output Security & Reliability	Pre-req	Critical	High
OUT-06	OUT — Output Security & Reliability	Pre-req	Critical	High
OUT-07	OUT — Output Security & Reliability	Pre-req	Critical	High
ACC-01	ACC — Access Control & Identity	Pre-req	Critical	High
ACC-04	ACC — Access Control & Identity	Pre-req	Critical	High
ACC-05	ACC — Access Control & Identity	Pre-req	Critical	High
MON-01	MON — Monitoring, Logging & Incident Response	Pre-req	Critical	High
MON-02	MON — Monitoring, Logging & Incident Response	Pre-req	Critical	High

Control ID	Domain	Implementation Phase	Risk if Absent	Implementation Complexity
MON-05	MON — Monitoring, Logging & Incident Response	Pre-req	Critical	High
VND-05	VND — Vendor & Third-Party AI Risk	Pre-req	Critical	High
DAT-03	DAT — Data Governance & Training Data Security	Pre-req	High	Medium
DAT-05	DAT — Data Governance & Training Data Security	Pre-req	High	Medium
DAT-06	DAT — Data Governance & Training Data Security	Pre-req	High	Medium
MOD-02	MOD — Model Security & Supply Chain	Pre-req	High	Medium
MOD-03	MOD — Model Security & Supply Chain	Pre-req	High	Medium
MOD-04	MOD — Model Security & Supply Chain	Pre-req	High	Medium
MOD-08	MOD — Model Security & Supply Chain	Pre-req	High	Medium
PRM-04	PRM — Prompt & Input Security	Pre-req	High	Medium
PRM-05	PRM — Prompt & Input Security	Pre-req	High	Medium
PRM-07	PRM — Prompt & Input Security	Pre-req	High	Medium
OUT-05	OUT — Output Security & Reliability	Pre-req	High	Medium
ACC-02	ACC — Access Control & Identity	Pre-req	High	Medium
MON-03	MON — Monitoring, Logging & Incident Response	Pre-req	High	Medium
MON-04	MON — Monitoring, Logging & Incident Response	Pre-req	High	Medium
MON-06	MON — Monitoring, Logging & Incident Response	Pre-req	High	Medium
VND-01	VND — Vendor & Third-Party AI Risk	Pre-req	High	Medium

Control ID	Domain	Implementation Phase	Risk if Absent	Implementation Complexity
VND-02	VND — Vendor & Third-Party AI Risk	Pre-req	High	Medium
VND-07	VND — Vendor & Third-Party AI Risk	Pre-req	High	Medium
MOD-05	MOD — Model Security & Supply Chain	Operational	Critical	Medium
MOD-06	MOD — Model Security & Supply Chain	Operational	Critical	Medium
DAT-08	DAT — Data Governance & Training Data Security	Operational	High	Medium
PRM-06	PRM — Prompt & Input Security	Operational	High	Medium
OUT-03	OUT — Output Security & Reliability	Operational	High	Medium
OUT-04	OUT — Output Security & Reliability	Operational	High	Medium
ACC-03	ACC — Access Control & Identity	Operational	High	Medium
ACC-06	ACC — Access Control & Identity	Operational	High	Medium
MON-07	MON — Monitoring, Logging & Incident Response	Operational	High	Medium
MON-08	MON — Monitoring, Logging & Incident Response	Operational	High	Medium
VND-03	VND — Vendor & Third-Party AI Risk	Operational	High	Medium
VND-08	VND — Vendor & Third-Party AI Risk	Operational	High	Medium
MOD-07	MOD — Model Security & Supply Chain	Periodic	High	Low
VND-04	VND — Vendor & Third-Party AI Risk	Periodic	High	Low
VND-06	VND — Vendor & Third-Party AI Risk	Periodic	High	Low
DAT-07	DAT — Data Governance & Training Data Security	Periodic	Medium	Low
ACC-07	ACC — Access Control & Identity	Periodic	Medium	Low

Control Attestation Template

AI System Name	[Enter name and brief description]		
Deployment Date	[DD/MM/YYYY]	**Accountable Owner**	[Name, Title, Department]

Status definitions: Implemented = control in place with evidence available. Partial = in place for some but not all scenarios, or evidence incomplete. Not Implemented = control not established. Not Applicable = does not apply to this system's architecture with documented justification.

Control ID	Control Status	Evidence Reference	Gap / Remediation	Reviewer Sign-off
DAT-01	**Implemented**	Training Data Registry v2.3, approved 14 Jan 2025	None	[Name / Date]
DAT-02	**Partial**	DPIA for 3 of 5 training datasets	DPIA for datasets 4 & 5 in progress. Target: 28 Feb 2025. Owner: DPO	[Name / Date]
DAT-04	**Not Implemented**	No checksum manifest in place	Remediation: Implement checksum verification in ML pipeline. Target: 31 Mar 2025. Owner: Head of MLOps	[Name / Date]
PRM-01	**Implemented**	System prompt in Azure Key Vault. Access log ref: AKV-2025-001	None	[Name / Date]
ACC-04	**Not Applicable**	N/A — system does not use RAG architecture	Justified: no retrieval component in this deployment	[Name / Date]
VND-02	**Partial**	Contract dated 1 Nov 2024 — missing model update notification clause	Amendment in negotiation. Compensating control: manual monitoring of vendor release notes. Owner: Head of Vendor Risk. Target: 30 Apr 2025	[Name / Date]

Control ID	Control Status	Evidence Reference	Gap / Remediation	Reviewer Sign-off

Regulatory Framework Cross-Reference

Navigate this table by regulatory reference to identify which control IDs satisfy each specific obligation. For the full NIST AI RMF to ISO 27001 mapping, see Deliverable 2 of 2.

Regulation	Reference	Obligation Summary	Relevant Control IDs
EU AI Act Art. 9		Conformity assessment, risk management system	MOD-01, MOD-02, PRM-01–03, OUT-01, OUT-02, OUT-06, ACC-01, MON-01
EU AI Act Art. 10		Data governance requirements for training data	DAT-01 through DAT-08, PRM-05, OUT-05
EU AI Act Art. 11 & 13		Technical documentation and transparency obligations	MOD-02, MOD-08, OUT-06
EU AI Act Art. 12		Record-keeping and logging obligations	OUT-07, MON-02, MON-03
EU AI Act Art. 14		Human oversight requirements	OUT-06, ACC-02
EU AI Act Art. 73		Serious incident reporting obligations	MON-05, MON-06, MON-07
DORA Art. 8 & 9		ICT risk management and access control	ACC-01–07, MON-01–03, all DAT controls
DORA Art. 17 & 18		ICT incident management and classification	MON-04, MON-05, MON-07, OUT-07
DORA Art. 28 & 30		Third-party risk management and contractual requirements	VND-01 through VND-08
GDPR Art. 5–6, 9		Lawful basis, data minimisation, special category data	DAT-02, DAT-05, PRM-05, OUT-05
GDPR Art. 17		Right to erasure in training data context	DAT-07
GDPR Art. 25 & 28		Privacy by design; data processing agreements	DAT-05, DAT-06, ACC-04, ACC-05, VND-05
ISO 42001 Cl. 8.4 & 8.5		AI system design, development, and operation	DAT-01–08, MOD-01–08, OUT-01–07, ACC-01–07
ISO 42001 Cl. 9.1 & 10.1		Performance monitoring and incident response	MON-01–08, OUT-03, OUT-04
NIST AI RMF GOVERN		Policies, accountability, third-party governance	VND-01–08, DAT-06, MOD-03, MOD-07
NIST AI RMF MEASURE (TEVV)		Testing, evaluation, verification, validation	OUT-02, PRM-02, PRM-03, PRM-06, MON-01